SIEM Design Document

This document will discuss the use of various different logging approaches and the reasoning behind each ones implementation and design.

SIEM Choice

Wazuh will be used as the security monitoring platform for the school Active Directory environment. Referring back to the scenario the budget for this project states an open source SIEM should be used. An alternative to this could be using proprietary software's free licenses however those can have limited functionality and usability. For this reason Wazuh was chosen to be the SIEM for this project. Although there were alternative open source options, Wazuh has vulnerability detection, compliance reporting and built in detection rules in an all in one system.

Log Sources

There are various different ingest sources of logging that can be monitored. The distinction between each one is what is being monitored and why. A Wazuh Windows agent will monitor these log channels: Security, System, Application, PowerShell, Sysmon and Windows Defender.

- **Security:** Authentication events such as failed logons (Event ID 4625), account creations (4720) and group member added (4728). Used to identify unauthorised account changes or potential misuse of user accounts. A failed logon attempt is not suspicious by itself however a repeating pattern of activity can be cause for concern.
- **System:** Service and operating system events such as unexpected shutdowns or driver activity. Monitoring allows for any unexpected changes to the OS or any suspicious service changes to be identified. An example of this is an attacker attempting to install a malicious Windows service on the workstation.
- **Application:** Application related events such as application crashes or application errors. Used to monitor unexpected behaviour and help identify potentially misconfigured or compromised software. The school's student record application keeps crashing and generating unexpected errors, it warrants investigation.
- **PowerShell:** Monitoring PowerShell script execution and command activity (Event ID 4104) enabled through a Group Policy. Used to identify potentially malicious scripts or suspicious administrative commands. An example being someone running PowerShell commands attempting to gain higher privilege access.
- **Sysmon (System Monitoring):** Process creation (Event ID 1), network connections (3) and other system activity. Sysmon is monitored to gain visibility into what processes are running and how they interact with each other. A compromised student workstation launches a PowerShell from an unusual parent process and tries to establish a connection with an unknown external IP address.
- **Windows Defender:** Malware detection (Event ID 1116) and protection status change (5000 or 5001). Defender actively scans for and removes/quarantines known malicious or

suspicious files. A workstation trying to download a malicious file will trigger Defender allowing for investigation or further action to take place.

By configuring the Wazuh configuration file the Wazuh agent can ingest all these logs and forward them to the Wazuh server which will alert if any suspicious activity is detected. Whilst Security, System and Applications are monitored by default. PowerShell, Sysmon and Defender will require additional configuration in the agent as well as additional Windows configurations.

Retention

The problem with log retention is finding the right balance between storage cost and legal compliance. When comparing different retention policies it is best to consider the scenario and conditions first. The problem with storing logs indefinitely is that Wazuh requires massive amounts of storage. Since this is a solo project with a simulated school, keeping everything in an active database would crash the virtual machine.

The solution to this problem is to store active logs for 30 days as this provides sufficient time for threat hunting or to investigate attacks. However, regulations like GDPR and KCSIE require evidence of access control are kept. Therefore, logs will be archived for 1 year in cold storage to satisfy the Ofsted and other regulatory body requirements.

Alert Philosophy

The problem with enabling every default Wazuh rule without tuning and monitoring the system that way is that Wazuh comes with thousands of default rules. Some rules might be too sophisticated or don’t apply to the system. Another issue with having too broad of a rule set is that every single failed login or minor application error will result in an administrator receiving an alert. This will result in alert fatigue and possibly lead to administrators missing the real attack.

A solution to this problem is finding the correct balance between depth and breadth and having a specific alert philosophy. For this environment a Behaviour Based Detection method will be used to detect sequences of events that indicate attacks rather than just static signatures.

Alerts will be prioritised based on risk. A single failed login might be a Level 3 alert resulting in logging but no actual alert. Whilst, a Kerberoasting attack or a user being added to the Domain Admins group could be a Level 12 critical alert.

The default Wazuh rules will be actively tuned by writing custom rules to suppress known administrative activity such as ignoring scheduled PowerShell scripts used by the school’s IT team. This ensures that when an alert does fire it is accurate and actionable.

Scope

Included

- **Identity Monitoring:** Ingesting logs from Domain Controller, File Server and Windows workstations.

- **Threat Detection:** Custom rules for specific MITRE ATT&CK techniques e.g. Kerberoasting and Password Spraying.
- **Attack Simulation:** Ensuring the SIEM captures the exact events and alerts generated by simulated attacks.

Not Included

- **Network Monitoring:** Ingesting firewall logs is out of scope as the focus is on Active Directory.
- **Full Packet Capture (PCAP):** The SIEM will not record raw network traffic.
- **SOC Operations:** There is going to be no automated threat hunting or real time human monitoring. This lab focuses on configuration and detection of an Active Directory environment.